

VULNERABILITY ASSESSMENT REPORT: KIFARUCART GLOBAL LTD.

DOCUMENT CONTROL

Table 1. Document Control

Attribute	Details
Organization	KifaruCart Global Ltd.
Document Title	Technical Vulnerability Assessment & Remediation Report
Assessment Date	August, 2026
Prepared By	Senior Vulnerability Assessment Analyst
Target Audience	Executive Management, IT Leadership, Operations Teams
Document Version	1.0 (Final Deliverable)
Overall Risk Level	HIGH

TABLE OF CONTENTS

EXECUTIVE SUMMARY 4

1. BUSINESS SCENARIO & INFRASTRUCTURE CONTEXT 4

2. ASSESSMENT OBJECTIVE & SYSTEM BOUNDARIES 5

 2.1 Assessment Objectives 5

 2.2 In-Scope vs. Out-of-Scope Assessment Boundaries..... 6

3. INFRASTRUCTURE & ARCHITECTURE PROFILE 6

4. CRITICAL ASSET INVENTORY 7

5. THREAT TAXONOMY & THREAT MODELING..... 8

6. RISK ASSESSMENT METHODOLOGY 8

7. VULNERABILITY RISK REGISTER..... 8

8. DETAILED ANALYSIS OF HIGHEST-PRIORITY VULNERABILITIES 10

 8.1 Priority 1: Unenforced Multi-Factor Authentication (V-001) 10

 8.2 Priority 2: Direct Internet Exposure of Production MySQL Database (V-003) 10

 8.3 Priority 3: Unrestricted Access Controls on Sensitive Cloud Storage (V-005) 10

 8.4 Priority 4: Absence of Authentication Rate Limiting & Account Lockout (V-002) 10

9. PHASED REMEDIATION ROADMAP..... 11

 Phase 1: Immediate Remediation (0 - 30 Days) 11

 Phase 2: Short-Term Remediation (31 - 60 Days) 11

 Phase 3: Medium-Term Remediation (61 - 90 Days)..... 12

 Phase 4: Long-Term Governance (90+ Days) 12

10. CONCLUSION..... 13

APPENDIX A: RISK RATING MATRIX GUIDE..... 13

APPENDIX B: ASSESSMENT ASSUMPTIONS & LIMITATIONS 13

LIST OF TABLES

No table of contents entries found.

EXECUTIVE SUMMARY

A technical vulnerability assessment was conducted for KifaruCart Global Ltd. to identify, quantify, and prioritize security weaknesses across its small-business e-commerce, cloud storage, payment handling, and logistics infrastructure. KifaruCart facilitates cross-border purchases for Kenyan customers buying from U.S.-based sellers. While the company has expanded its digital footprint, security governance and technical controls have not matured at a corresponding rate.

The assessment evaluated customer and administrative web portals, MySQL database instances, cloud file repositories, email systems, operational endpoints, local network configurations, and data backup workflows.

KifaruCart's overall technical risk level is assessed as HIGH. The evaluation uncovered 20 distinct technical vulnerabilities across 10 critical asset categories. The most critical security risks involve:

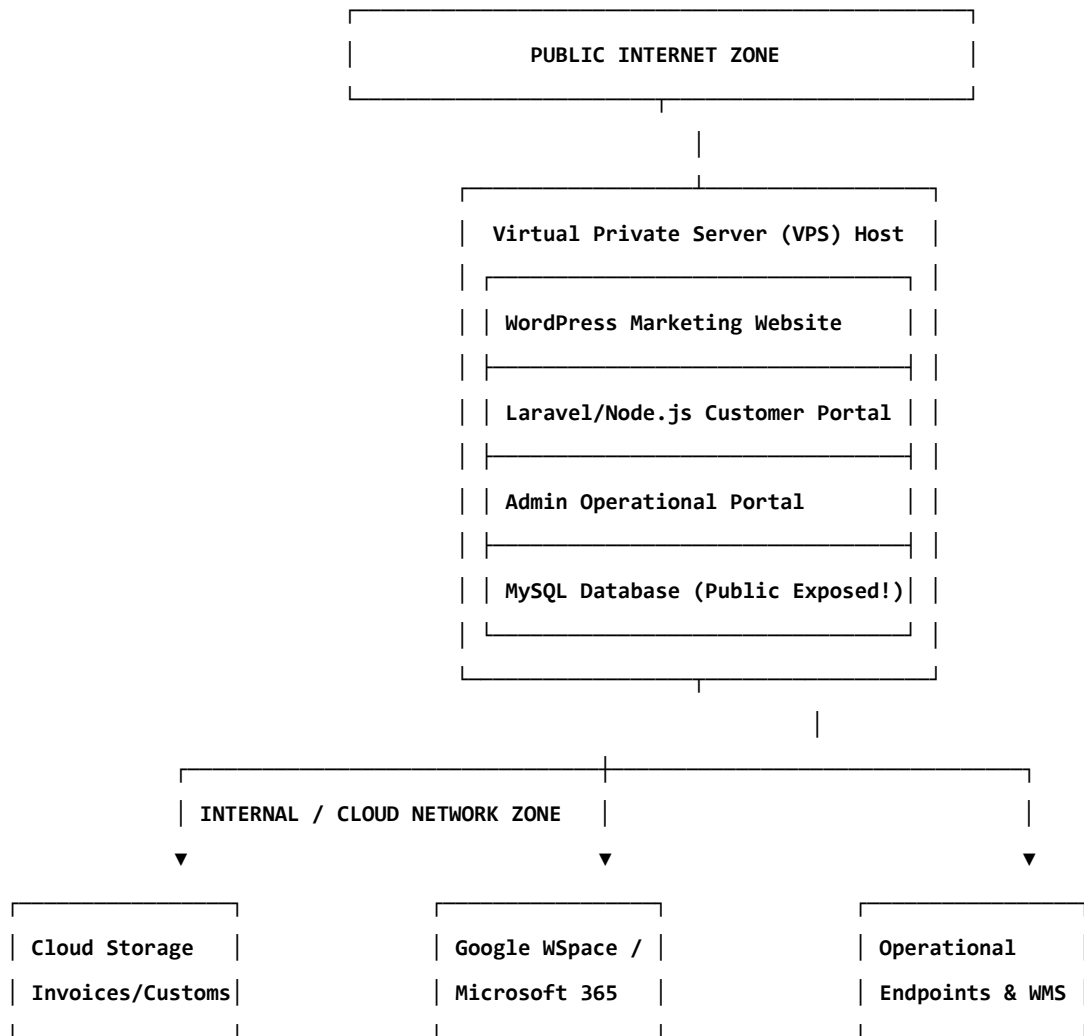
- Unenforced Multi-Factor Authentication (MFA) on administrative portals and cloud services.
- Direct public internet exposure of the primary MySQL production database.
- Missing login rate-limiting and lockout mechanisms on web entry points.
- Overly broad staff access permissions to unencrypted payment and customs records.
- Absence of structured anti-phishing training and lack of centralized log auditing.

Immediate execution of the phased remediation roadmap outlined in Section 9 will mitigate the likelihood of account compromise, customer PII exposure, financial fraud, and business operational disruption.

1. BUSINESS SCENARIO & INFRASTRUCTURE CONTEXT

KifaruCart Global Ltd. operates an e-commerce and logistics platform connecting Kenyan buyers with U.S. merchants. The operational model relies on a hybrid digital and physical footprint across Kenya and the United States, managing customer accounts, order processing, customs clearing, package tracking, and local delivery.

Rapid business growth has resulted in a technical architecture reliant on manual procedures, default software configurations, and unmanaged endpoints. Management commissioned this vulnerability assessment to establish a risk baseline and prioritize technical remediation before expanding operations.



2. ASSESSMENT OBJECTIVE & SYSTEM BOUNDARIES

2.1 Assessment Objectives

The primary objectives of this vulnerability assessment were to:

1. Inventory critical information technology assets supporting business operations.
2. Identify threat sources targeting KifaruCart's operational profile.
3. Uncover technical and operational vulnerabilities across the infrastructure.
4. Quantify risk levels using a standardized Likelihood x Impact scoring model.
5. Formulate a prioritized Risk Register and actionable remediation roadmap.

2.2 In-Scope vs. Out-of-Scope Assessment Boundaries

Table 2. Assessment Boundaries

Infrastructure Component	Scope Status	Operational Context & Boundary Notes
Customer E-Commerce Portal	In Scope	Laravel/Node.js web application used for order intake and delivery tracking.
Admin Operations Dashboard	In Scope	Web dashboard used by staff to process payments, refunds, and shipments.
MySQL Database Instance	In Scope	Production database hosting customer profiles, orders, and system records.
Cloud File Repositories	In Scope	Google Drive / OneDrive folders storing payment receipts and customs docs.
Corporate Email Systems	In Scope	Google Workspace / M365 accounts used for staff communications.
Staff Workstations	In Scope	18 Windows laptops utilized by support, finance, and warehouse staff.
Warehouse Endpoints	In Scope	4 Android tablets and 3 barcode scanners processing package intake.
Wireless Networks	In Scope	Office routers, warehouse routers, and guest Wi-Fi access points.
Backup Workflows	In Scope	Cloud and external drive backup routines evaluated for recoverability.
Payment Gateway Backends	Out of Scope	Third-party payment gateway infrastructure (only internal receipts audited).
External E-Commerce Platforms	Out of Scope	External seller sites (Amazon, eBay, Walmart).
Courier Delivery Networks	Out of Scope	Third-party logistics partner platforms and APIs.

3. INFRASTRUCTURE & ARCHITECTURE PROFILE

Table 3. Infrastructure and Architecture Profile

Technical Layer	Deployed Architecture & Configuration State
Web Server Environment	Single Virtual Private Server (VPS) hosting WordPress and Laravel/Node.js web portals.
Database Architecture	Standalone MySQL database instance hosted on the public VPS instance.
Cloud File Storage	Unstructured Google Drive and Microsoft OneDrive directories for invoices and customs forms.
Identity & Authentication	Standalone username/password credentials; MFA enforced exclusively for IT Admin.
Workstations & Endpoints	18 Windows laptops, 4 Android warehouse tablets, and 3 handheld barcode scanners.
Network Infrastructure	1 office router, 1 warehouse router, and 1 unsegmented guest Wi-Fi network.
Logging & Monitoring	Basic local web server logs; no SIEM, centralized log collector, or active alerting.
Endpoint Safeguards	Basic standalone antivirus on select workstations; no centralized EDR or patch management.

4. CRITICAL ASSET INVENTORY

Table 4. Critical Asset Inventory

Asset ID	Critical Asset	Primary Business Function	Data Handled / Stored	Criticality Level
A-001	Customer Portal	Registration, ordering, package tracking	Customer PII, order records, addresses	High
A-002	Admin Portal	Order, refund, and shipment processing	Payment receipts, shipment data, customer PII	Critical
A-003	MySQL Database	Primary data persistence layer	Profiles, order details, addresses, login hashes	Critical
A-004	Cloud Storage	Document archiving and storage	Invoices, clearing receipts, customs forms	High
A-005	Corporate Email	Internal and vendor communication	Vendor records, customer messages, attachments	High
A-006	Staff Laptops	Workstation administration and tasks	Active web sessions, cached credentials, docs	High
A-007	Warehouse Tablets	Physical package processing and intake	Package IDs, delivery status, customer names	Medium
A-008	Wi-Fi Infrastructure	Internal network connectivity	Internal transit traffic, operational connections	Medium
A-009	Backup Storage	Business recovery and disaster resilience	Full database dumps and application files	High
A-010	Payment Folder	Payment verification and financial audits	Invoices, transaction references, receipts	High

5. THREAT TAXONOMY & THREAT MODELING

Table 5. Threat Taxonomy and Threat Modeling

Threat Source	Threat Category	Threat Description & Attack Vector
External Attacker	Network / Web Attack	Attempts credential stuffing, SQL injection, or admin dashboard compromise via exposed endpoints.
Cybercriminal Group	Ransomware / Extortion	Attempts financial extortion, database encryption, or payment receipt theft via malware.
Malicious Insider	Data Misuse	Exfiltrates customer delivery databases or authorizes fraudulent payment refunds.
Negligent Employee	Human Error / Phishing	Discloses login credentials via phishing, shares passwords, or misplaces unencrypted endpoints.
Opportunistic Scanner	Automated Exploitation	Scans public IP ranges to identify exposed database ports, open shares, and unpatched software.
Fraudulent Customer	Financial Fraud	Submits altered payment transaction records or exploits single-user refund workflows.
Physical Intruder	Device Theft	Enters warehouse or office space after hours to steal physical laptops or tablets.

6. RISK ASSESSMENT METHODOLOGY

Vulnerabilities were evaluated using a qualitative 5x5 Likelihood and Impact scoring matrix. The overall Risk Score is calculated as:

Risk Score = Likelihood Score (1-5) x Impact Score (1-5)

Table 6. Risk Rating Scale and Action Priorities

Score Range	Risk Rating	Priority Level	Action Timeline
17 - 25	Critical	P1	Immediate mitigation required (0 - 30 Days).
10 - 16	High	P2	Short-term remediation required (31 - 90 Days).
5 - 9	Medium	P3	Long-term operational remediation (90+ Days).
1 - 4	Low	P4	Accept risk or remediate during routine maintenance.

7. VULNERABILITY RISK REGISTER

The following master register details all 20 technical vulnerabilities identified during the assessment.

Table 7. Vulnerability Risk Register

Risk ID	Asset	Identified Threat Vector	Vulnerability Description	L (1-5)	I (1-5)	Risk Score	Rating	Priority
V-001	Admin Portal	Account Takeover	MFA is unenforced across staff accounts	5	5	25	Critical	P1
V-002	Customer Portal	Web App Attack	Login lacks rate limiting and lockout mechanisms	4	5	20	Critical	P1

Risk ID	Asset	Identified Threat Vector	Vulnerability Description	L (1-5)	I (1-5)	Risk Score	Rating	Priority
V-003	MySQL Database	Direct DB Attack	Database port is bound to public internet	4	5	20	Critical	P1
V-004	Admin Portal	Fraud / Modification	Administrative actions are unlogged and unmonitored	4	4	16	High	P2
V-005	Cloud Storage	Data Exposure	Payment/customs folders have open staff permissions	4	5	20	Critical	P1
V-006	Corporate Email	Phishing Attack	Absence of security awareness or anti-phishing training	5	4	20	Critical	P1
V-007	Staff Laptops	Endpoint Theft	Laptops lack managed full-disk drive encryption	3	5	15	High	P2
V-008	Web Server / VPS	Web Exploit	WordPress plugins and OS packages are unpatched	4	4	16	High	P2
V-009	Backup Storage	Ransomware / Loss	Backups are unencrypted and untested for restore	3	5	15	High	P2
V-010	Office Wi-Fi	Network Intrusion	Corporate Wi-Fi and Guest Wi-Fi are unsegmented	3	4	12	High	P2
V-011	Warehouse Tablets	System Misuse	Shared generic credentials used on warehouse devices	4	3	12	High	P2
V-012	Payment Workflow	Payment Fraud	Refund processing lacks separation of duties	3	5	15	High	P2
V-013	Customer Portal	MITM / Clickjacking	Security headers (CSP, HSTS) missing on web portal	3	3	9	Medium	P3
V-014	Code Repository	Credential Exposure	Hardcoded API keys and secrets in application code	3	5	15	High	P2
V-015	User Directory	Unauthorized Access	Inconsistent deprovisioning of departed staff accounts	3	4	12	High	P2
V-016	Logging Systems	Delayed Detection	Complete absence of centralized SIEM or log collection	4	4	16	High	P2
V-017	Cloud Storage	Compliance Exposure	Indefinite data retention of old customer PII	3	4	12	High	P2
V-018	Vendor Management	Third-Party Risk	Absence of formal security evaluation for suppliers	3	3	9	Medium	P3
V-019	Staff Laptops	Malware Infection	Antivirus is installed standalone and unmanaged	3	4	12	High	P2
V-020	Customer Database	Data Integrity Loss	Shipment status changes lack approval workflows	3	4	12	High	P2

8. DETAILED ANALYSIS OF HIGHEST-PRIORITY VULNERABILITIES

8.1 Priority 1: Unenforced Multi-Factor Authentication (V-001)

- Affected Assets: Admin Portal, Corporate Email, Cloud Repositories.
- Technical Threat Vector: Attackers leveraging stolen credentials obtained via phishing or credential stuffing gain direct access to administrative functions.
- Business Impact: Full compromise of administrative dashboard, customer profile leakage, unauthorized refund issuance, and operational disruption.
- Remediation Requirement: Mandate authenticator-based MFA across Google Workspace, M365, and the Admin Portal.

8.2 Priority 2: Direct Internet Exposure of Production MySQL Database (V-003)

- Affected Assets: Primary MySQL Database (A-003).
- Technical Threat Vector: Automated network scanners identify open database ports (3306) on the public VPS IP address, initiating brute-force credential attacks.
- Business Impact: Database compromise, customer PII theft, record encryption by ransomware, and loss of business data integrity.
- Remediation Requirement: Modify firewall rules to block public database port exposure, restricting access exclusively to localhost or internal VPN connections.

8.3 Priority 3: Unrestricted Access Controls on Sensitive Cloud Storage (V-005)

- Affected Assets: Cloud Storage Directories (A-004), Payment Files (A-010).
- Technical Threat Vector: Operational personnel across support and logistics access confidential payment receipts, customs forms, and identity documents.
- Business Impact: Internal misuse, customer data privacy violations, non-compliance with ODPC regulations, and potential fraud.
- Remediation Requirement: Restrict cloud file folder access using Role-Based Access Control (RBAC) and institute quarterly permission reviews.

8.4 Priority 4: Absence of Authentication Rate Limiting & Account Lockout (V-002)

- Affected Assets: Customer Portal (A-001), Admin Portal (A-002).
- Technical Threat Vector: Automated scripts submit thousands of password attempts against customer and staff login interfaces without triggering lockouts.
- Business Impact: Account takeover, customer credential theft, and portal downtime caused by brute-force traffic overload.
- Remediation Requirement: Deploy web application rate limiting (e.g., maximum 5 failed login attempts per minute) and enforce temporary account lockouts.

9. PHASED REMEDIATION ROADMAP

Phase 1: Immediate Remediation (0- 30 Days)

Table 8. Phase 1 Immediate Remediation (0-30 Days)

Priority	Action Item	Target System	Responsible Owner	Expected Risk Reduction Outcome
P1	Enforce mandatory MFA for all staff email, cloud, and portal accounts.	Identity / Admin	IT Manager	Eliminates single-factor credential takeover vectors.
P1	Restrict MySQL database access exclusively to localhost / internal network.	MySQL DB / VPS	Lead Developer	Prevents external direct database connection attacks.
P1	Reconfigure cloud directory permissions for payment and customs folders.	Cloud Storage	IT + Operations	Eliminates unauthorized internal exposure of PII.
P1	Implement login rate limiting and lockout rules on web portals.	Web Application	Lead Developer	Prevents automated brute-force attacks.
P1	Disable inactive accounts and implement offboarding checklist.	Identity Management	HR + IT Support	Eliminates stale account unauthorized access risks.
P2	Mandate dual-authorization for all customer payment refund processing.	Admin Portal	Finance Manager	Mitigates single-user payment fraud vectors.

Phase 2: Short-Term Remediation (31- 60 Days)

Table 9. Phase 2 Short-Term Remediation (31-60 Days)

Priority	Action Item	Target System	Responsible Owner	Expected Risk Reduction Outcome
P2	Configure administrative activity logging in the Admin Portal and WMS.	Web Dashboard	Lead Developer	Establishes accountability for administrative updates.
P2	Aggregate VPS server logs and application logs into a central log repository.	Logging Host	IT Manager	Enables timely detection of security anomalies.
P2	Deploy BitLocker / FileVault managed full-disk encryption across all laptops.	Workstations	IT Support	Protects data on lost or stolen laptops.
P2	Separate Guest Wi-Fi traffic into an isolated VLAN away from corporate assets.	Routers / Wi-Fi	IT Support	Prevents unauthorized internal network access.
P2	Patch WordPress plugins, core OS packages, and web dependencies.	VPS Host	Lead Developer	Eliminates known public software vulnerabilities.
P2	Revoke generic warehouse credentials and issue individual user logins.	Warehouse Devices	Operations + IT	Establishes auditability for package updates.

Phase 3: Medium-Term Remediation (61- 90 Days)

Table 10. Phase 3 Medium-Term Remediation (61-90 Days)

Priority	Action Item	Target System	Responsible Owner	Expected Risk Reduction Outcome
P2	Deploy centrally managed Endpoint Detection and Response (EDR) software.	Workstations	IT Manager	Improves malware containment and mitigation.
P2	Encrypt backup files and conduct a full database restoration test.	Backup Storage	IT Manager	Ensures recovery capabilities during ransomware incidents.
P2	Roll out employee security awareness training and phishing simulations.	Workforce	HR + IT	Reduces human susceptibility to social engineering.
P2	Hardcode environment secrets into secure vault managers rather than code repos.	Source Code	Lead Developer	Prevents credential exposure in codebase files.
P2	Establish formal approval workflows for status changes in WMS.	WMS Application	Operations + IT	Maintains package tracking data integrity.
P3	Implement HTTP security headers (CSP, HSTS, X-Frame-Options) on portals.	Web Server	Lead Developer	Strengthens baseline browser security posture.

Phase 4: Long-Term Governance (90+ Days)

Table 11. Phase 4 Long-Term Governance (90+ Days)

Priority	Action Item	Target System	Responsible Owner	Expected Risk Reduction Outcome
P2	Deploy a lightweight SIEM dashboard for automated threat alerting.	Monitoring Host	IT Manager	Automates security monitoring and incident response.
P2	Establish quarterly automated vulnerability scanning schedules.	Infrastructure	IT Manager	Continuously identifies new technical weaknesses.
P2	Institute a formal Vendor Risk Management security checklist.	Supply Chain	Operations + IT	Mitigates third-party supply chain risks.
P2	Establish a Data Classification and Purging Policy for old records.	Cloud Storage	Legal + IT	Aligns operations with ODPC data retention laws.
P3	Document updated network topology and cross-border data-flow diagrams.	Governance	IT Manager	Enhances visibility over operational data flows.
P3	Commission an annual third-party penetration test and re-assessment.	Enterprise	Executive Leadership	Validates ongoing security posture improvements.

10. CONCLUSION

The technical vulnerability assessment indicates that KifaruCart Global Ltd. faces elevated cybersecurity risks driven by rapid operational growth that has outpaced its technical security controls. The identified vulnerabilities-most notably unenforced MFA, public database exposure, unencrypted data stores, and unmonitored administrative actions-expose the business to account takeover, payment fraud, regulatory penalties, and operational downtime.

Because KifaruCart handles sensitive customer identities, physical addresses, customs clearance records, and payment confirmations across international borders, maintaining data confidentiality and integrity is essential.

By systematically executing the phased remediation plan over the next 90 days, KifaruCart can neutralize its critical risk vectors immediately while establishing a resilient, scalable security baseline.

APPENDIX A: RISK RATING MATRIX GUIDE

Risk levels are assigned based on the intersection of Likelihood and Impact scores.

Table 12. Risk Rating Matrix Guide

Likelihood / Impact	1 Minimal	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost Certain	5 Medium	10 High	15 High	20 Critical	25 Critical
4 Likely	4 Low	8 Medium	12 High	16 High	20 Critical
3 Possible	3 Low	6 Medium	9 Medium	12 High	15 High
2 Unlikely	2 Low	4 Low	6 Medium	8 Medium	10 High
1 Rare	1 Low	2 Low	3 Low	4 Low	5 Medium

APPENDIX B: ASSESSMENT ASSUMPTIONS & LIMITATIONS

1. Non-Intrusive Evaluation: This vulnerability assessment was conducted using non-intrusive architecture reviews, configuration audits, and administrative interviews. Active penetration testing and exploitation were excluded.
2. Fictionalized Environment Profile: The assessment evaluated KifaruCart's designated architecture profile comprising 18 workstations, 4 Android tablets, 3 barcode scanners, and single VPS host instances.
3. Out-of-Scope Dependencies: Security controls operated by third-party payment gateways, external e-commerce platforms (e.g., Amazon, eBay), and courier logistics backends were assumed to be maintained by their respective service providers.